

Vendor Security Assessment Questionnaire - 2026

Vendor: Sample Inc. Please provide a response to each question below.

1. ENCRYPTION

Is customer data encrypted at rest? Specify the algorithm and key management.

Response: _____

2. ENCRYPTION

Is data encrypted in transit? What is the minimum TLS version supported?

Response: _____

3. ENCRYPTION

How are encryption keys and application secrets managed?

Response: _____

4. ACCESS CONTROL

Do you enforce multi-factor authentication (MFA) for employees?

Response: _____

5. ACCESS CONTROL

Do you support SSO/SAML and SCIM provisioning for customers?

Response: _____

6. ACCESS CONTROL

How frequently are user access rights reviewed?

Response: _____

7. ACCESS CONTROL

How quickly is access revoked when an employee is terminated?

Response: _____

8. COMPLIANCE

Are you SOC 2 Type II compliant? What is the scope of the report?

Response: _____

9. COMPLIANCE

Are you ISO 27001 certified?

Response: _____

10. COMPLIANCE

Can you provide your audit reports, and under what conditions?

Response: _____

11. INCIDENT RESPONSE

Do you have a documented incident response plan?

Response: _____

12. INCIDENT RESPONSE

What is your breach notification timeline to affected customers?

Response: _____

13. AVAILABILITY

What are your Recovery Time Objective (RTO) and Recovery Point Objective (RPO)?

Response: _____

14. AVAILABILITY

What is your target uptime / availability commitment?

Response: _____

15. AVAILABILITY

Is your platform deployed across multiple availability zones?

Response: _____

16. VULNERABILITY MGMT

How often do you perform penetration testing, and by whom?

Response: _____

17. VULNERABILITY MGMT

How frequently do you scan for vulnerabilities and what are the remediation SLAs?

Response: _____

18. DATA MANAGEMENT

How long is customer data retained after contract termination?

Response: _____

19. DATA MANAGEMENT

How long are audit logs retained?

Response: _____

20. DATA MANAGEMENT

Do you use customer data to train AI models?

Response: _____

21. BACKUP

Do you have a documented backup policy? Are backups encrypted and tested?

Response: _____

22. PERSONNEL

Do you conduct background checks on employees?

Response: _____

23. PERSONNEL

How often do employees complete security awareness training?

Response: _____

24. VENDOR / PRIVACY

Do you maintain a list of subprocessors and offer a DPA?

Response: _____

25. INFRASTRUCTURE

Which cloud provider hosts your platform and in which regions?

Response: _____

26. DEVELOPMENT

Is production data used in development or test environments?

Response: _____

27. EMERGING TECH

What is your roadmap for post-quantum / quantum-resistant encryption in 2027?

Response: _____

28. PHYSICAL SECURITY

How many security guards staff your on-premise data center 24/7?

Response: _____